INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Incident Response Planning Assignment

GRC105 Incident Management and Business Continuity, Week 20

Northbridge Skills Institute: suspected ransomware incident (fictional case)

Submission detail	Entry
Student name	Nunoo Annah Frimpomaah
Student ID	2025/GCR/12656
Official email	gcr2512656@students.icdfa.edu.ng
Filename	GRC105_IRP_Assignment_2025/GCR/12656.docx
Word count	About 10,000 words (whole document, including tables and references)
AI assistance	My own work. AI tools (ChatGPT Pro, Gemini, Claude Pro) were used for review, language editing and formatting support. See the AI Assistance Statement after the References.

Contents

Role, scope and assumptions 3

Task 1: Incident classification and initial assessment 4

1.1 Evidence-linked timeline 4

1.2 Other possible explanations 4

1.3 Incident type and severity 5

1.4 Affected assets and CIA impact 6

1.5 Priority investigation questions 7

Task 2: Incident response plan and team responsibilities 8

2.1 Policy and plan outline 8

2.2 CSIRT structure 8

2.3 RACI matrix 9

2.4 Readiness improvements and checklist 10

Task 3: Response playbook and evidence preservation 11

3.1 Playbook for the first 24 hours 11

3.2 Checking for wider compromise 13

3.3 Two difficult decisions 13

3.4 Evidence register and chain of custody 14

3.5 Eradication, credentials, recovery and acceptance 15

Task 4: Communication and escalation 18

4.1 Communication matrix 18

4.2 Executive briefing (09:20 WAT, Day 0) 19

4.3 Learner notice (09:50 WAT, Day 0) 19
4.4 Notification duties 19
Task 5: Tabletop exercise and improvement plan 21
5.1 Exercise design 21
5.2 Simulated walkthrough by role 21
5.3 Decision log 23
5.4 Evaluation against success criteria 24
5.5 Improvement plan 24
Task 6: Case study analysis and critical reflection 26
References 27

Role, scope and assumptions

I act as the Incident Response Lead (IR Lead) for Northbridge Skills Institute. I take control at 08:45 on Day 0 (Monday). All times are West Africa Time (WAT). Day minus 1 is Sunday and Day minus 3 is Friday. The online examination for 100 learners starts at 11:00, so I have 135 minutes before it begins.

E01 to E08 refer to the evidence pack in the brief. I keep three things apart throughout: what the evidence **confirms**, what I **suspect** (working hypotheses), and what is still **unknown**. The evidence does not prove who the attacker is or that personal data was stolen.

Everything in this report is a **plan or a simulation**. No evidence has been collected, no hash values exist, and all names and phone numbers are fictional. The report follows the four teaching stages: preparation; detection and analysis; containment, eradication and recovery; and post-incident activity (ICDFA, n.d.). When I cite NIST SP 800-61 Revision 3, I use its CSF 2.0 link: Govern, Identify and Protect support preparation, while Detect, Respond and Recover make up incident response (NIST, 2025).

Table A. Assumptions (A1 to A7 are used in later tasks)

ID	Assumption
A1	The Principal is the Executive Sponsor. The Principal has given the IR Lead authority to isolate systems and accounts at once, and must be told within 15 minutes.
A2	Northbridge operates in Ghana (the case uses WAT). Ghana's Data Protection Act, 2012 (Act 843) is therefore the main privacy law to check. The legal adviser must confirm this, and check whether any learners are covered by other countries' laws.
A3	Staff mobile phones work (E08), so a phone call tree can start within minutes.
A4	Identity is mainly Microsoft 365. If an on-premises Active Directory also exists, it is included in password resets.
A5	Master copies of the examination papers exist outside FS01 (for example, with the academic department). This must be confirmed in the first hour.
A6	Northbridge has, or can quickly hire, an external digital forensics provider and has cyber insurance. Names used here are fictional.
A7	The Friday 17:00 disconnected backup is intact and offline. It is about 64 hours older than the start of my control (Friday 17:00 to Monday 08:45).

Task 1: Incident classification and initial assessment

1.1 Evidence-linked timeline

The table below separates what is confirmed from what I suspect and what I still need to find out. Hypotheses may change as facts arrive.

Table 1. Timeline, hypotheses and open questions

ID	Time (WAT)	Confirmed observation	Working hypothesis	Unresolved question
E01	Day −1 (Sun) 16:40	A finance officer opened an unexpected payroll attachment on FIN-PC07 (user report and mail record).	The attachment was a phishing lure and the way in.	Did any code actually run? What was the file type, sender and delivery route?
E02	Day 0 01:15	The officer's Microsoft 365 account signed in from an unfamiliar IP on a new device.	The attacker stole the password or a session token after E01.	Was MFA asked for and passed? Was it really the officer?
E03	Day 0 01:35	svc_backup made remote admin logons to FS01 and BAK01 outside its normal schedule.	The attacker used this powerful account to move to the file server and the backups.	Which machine did the logons come from? Was any maintenance approved?
E04	Day 0 01:50	FIN-PC07 uploaded 1.2 GB over HTTPS to unfamiliar cloud storage.	Data was copied out to use for extortion ("double extortion").	What files were sent? Do they contain learner or finance data?
E05	Day 0 02:00	The backup console says the FS01 and LMS01 jobs succeeded.	The jobs ran, but the copies may have been changed or reached by the attacker after E03.	Can the copies be read? Are they complete and free of malware?
E06	Day 0 08:30	Mass file changes on FIN-PC07; FS01 shares hold .locked files and a ransom note.	Ransomware ran on FIN-PC07 and reached FS01 using admin access.	Which malware family? Is encryption still spreading? Which other hosts are hit?
E07	Day 0 08:40	The portal login page loads, but learners cannot open materials or submit work.	LMS01 depends on files on FS01, so it may be failing only because FS01 is encrypted.	Is LMS01 itself encrypted or changed?
E08	Day 0 08:45	The incident contact list on FS01 cannot be opened; staff phones work.	The list was lost because FS01 was encrypted.	Is corporate email safe? Has the attacker read or sent mail?

1.2 Other possible explanations

Some events can be explained in more than one way. I do not assume the worst without checking, but I plan for it until it is ruled out.

Table 2. Alternative explanations and how to tell them apart

Event	Malicious explanation	Harmless or different explanation	Check that separates them
E02	Attackers used a stolen password or session token.	The officer signed in late on a new phone, or through a VPN or travel network.	Entra ID sign-in logs (MFA result, device ID, token type); phone interview with the officer; check for new MFA methods or inbox rules.
E03	Attackers used svc_backup to reach FS01 and BAK01 before encrypting.	IT staff or a catch-up backup task ran out of hours (a three-person team may work late).	Source IP and host of the logon; change tickets; interview IT; check whether the commands match normal backup tasks.
E04	Data theft to the attacker's cloud account.	A normal sync tool or the officer's personal cloud app sent routine files.	Destination reputation; which process made the connection (EDR); file-access history on FIN-PC07.
E05	Backups were tampered with or hold infected data.	Jobs ran normally at 02:00, before encryption at about 08:30, so the copies may be clean.	Tests restore in an isolated network; check catalogue integrity and job settings history; scan restored data.
E07	LMS01 itself is compromised or encrypted.	LMS01 is healthy but cannot read its content on FS01.	LMS01 host logs; file integrity check; map which portal paths point to FS01.

1.3 Incident type and severity

Incident type: suspected human-operated ransomware with possible data theft (double extortion). The finance officer's account, the svc_backup account and the backup repository may also be compromised. The malware family and attackers are unknown, and data theft is not proven (E04, E06).

Table 3. Severity criteria

Level	Criteria (any one is enough)	Expected response
Critical	A core service is lost or at immediate risk with a fixed deadline; sensitive personal or finance data may be exposed at scale; backups or identity systems may be compromised, so recovery is uncertain; or the attack is still spreading.	Declare incident; full CSIRT within 15 minutes; Executive Sponsor told within 15 minutes; legal adviser and outside help within 60 minutes; updates at least hourly.
High	Serious disruption to an important service, or limited exposure of sensitive data, with a risk of spread but no loss of recovery ability.	Core CSIRT activated; management told within 60 minutes; updates every 2 to 4 hours.
Medium	One non-critical system affected and contained; no sign of sensitive data exposure or spread.	Security Analyst and IT lead handle it; daily summary to management.
Low	A single endpoint event, quickly contained, with no data impact.	Handled by IT as routine; logged and reviewed weekly.

Initial severity: Critical (provisional). My reasons:

- **Operational impact:** FS01 shares are encrypted, and learners cannot open materials or submit work (E06, E07). The contact list is lost (E08). The 11:00 examination for 100 learners is at risk.
- **Affected data:** Northbridge holds contact details, admission documents, assessment records and finance files for 1,800 learners. 1.2 GB left the network (E04), but we do not know what it contained.
- **Uncertainty:** the backups, svc_backup and the finance officer's account may all be compromised (E02, E03, E05), so I cannot yet say recovery is safe. When the facts are unclear and the possible harm is serious, I choose the higher level and lower it later if the evidence allows. I will review the rating at 10:00 and at each investigation milestone.

1.4 Affected assets and CIA impact

Table 4. Asset status

Asset	Status	Basis
FIN-PC07 (finance workstation)	Confirmed affected	Mass file changes (E06); suspicious upload (E04); likely entry point (E01).
FS01 (file server)	Confirmed affected	.locked files and ransom note (E06); out-of-hours admin logon (E03).
LMS01 (learning portal)	Impaired; cause unknown	Materials and submissions fail (E07); depends on FS01.
BAK01 (backup repository)	Potentially affected	Out-of-hours admin logon (E03); backups are not immutable; a “success” message is not proof of safety (E05).
svc_backup account	Potentially compromised	Unusual logons (E03); have admin rights on both FS01 and BAK01.
Finance officer's M365 account	Potentially compromised	Unfamiliar IP and device (E02).
Microsoft 365 email and identity	Potentially affected	Email trust not yet confirmed (E08).
Other servers and endpoints	Unknown	Server EDR coverage is incomplete, so spread cannot be ruled out.

Table 5. Confidentiality, integrity and availability

Property	Rating	Reasoning
Confidentiality	Potentially high	The unfamiliar sign-in (E02), the 1.2 GB upload (E04) and the ransom note point to possible theft, but nothing yet shows what data left. Learner and finance records are sensitive.
Integrity	High concern	Files on FIN-PC07 and FS01 were changed (E06). We cannot yet trust the backups or LMS01 content (E05, E07).
Availability	Confirmed loss	FS01 shares, portal materials, assessment submissions and the contact list are unavailable (E06 to E08).

Table 6. Response priorities

Rank	Priority	Reason
1	Stop the spread: isolate FIN-PC07 and FS01; protect BAK01; disable svc_backup; end the finance officer's sessions.	Encryption and attacker access may still be active (E03, E06). Clean backups are our way back.
2	Preserve memory and log evidence while containing.	Needed to find the entry point, scope and any data theft.
3	Coordinate by phone and treat email as untrusted.	E08.
4	Decide on the 11:00 examination by 09:45. Go ahead only with a clean, tested environment; otherwise reschedule.	The deadline is 135 minutes away and the backups are unverified (E05).
5	Confirm the scope and whether backups are safe; bring in legal, insurer and forensic partner.	These drive restoration and notification decisions.

1.5 Priority investigation questions

Table 7. Investigation priorities

Question	Evidence or check that answers it	How the answer would change severity or scope
Q1. Did malicious code run on FIN-PC07, and how did the attacker get in? (E01, E02)	EDR process tree; Windows event logs; Amcache and Prefetch; mail trace and sandbox test of the attachment; interview with the finance officer.	If the attachment did not run, there is another way in, and scope widens to other hosts and accounts. If it did, scope centres on the finance officer's environment.
Q2. Was svc_backup misused, and can we trust the backups? (E03, E05)	Logon source and session logs on FS01 and BAK01; backup job and catalogue history; change tickets; IT interview; isolated test restore.	If misused: network backups are untrusted, we must use the Friday offline copy (about 64 hours of data loss), and severity stays Critical. If it was normal maintenance: confidence in backups rises and recovery may be faster.
Q3. What was in the 1.2 GB upload? (E04)	Proxy, firewall and DNS logs; EDR file and process data; file-access history on FIN-PC07; M365 download audit.	If learner or finance personal data was sent: a breach assessment starts and severity stays Critical. If not: the confidentiality rating falls, though the extortion threat is still handled.
Q4. Is LMS01 itself compromised? (E07)	LMS01 host logs and EDR (if present); file integrity comparison; dependency mapping.	If it is only a dependency on FS01, the portal can return sooner once content is restored. If compromised, LMS01 must be rebuilt and scope grows.
Q5. Does the attacker control other accounts or email? (E02, E08)	Entra ID sign-in and audit logs; MFA method changes; inbox rules; OAuth app grants; other sign-ins from the same IP.	If yes, email stays out of use, more passwords are reset, and cloud services are added to scope.

Task 2: Incident response plan and team responsibilities

2.1 Policy and plan outline

Table 8. Incident response policy and plan

Element	Content
Mission	Protect learners, staff and data, and bring teaching and assessment back safely and quickly, using decisions based on evidence.
Objectives	Detect and classify incidents within one hour; stop the spread; preserve evidence; restore only systems that have been tested and are clean; meet legal duties; communicate accurately; learn and improve.
Scope	All Northbridge systems (FIN-PC07, FS01, LMS01, BAK01, all endpoints, Microsoft 365), plus staff, learners, contractors and service providers that handle Northbridge data.
Incident declaration	The IR Lead (or deputy) declares an incident when there is credible evidence of malicious activity affecting Northbridge systems or data. Examples: ransomware signs, misuse of an admin account, suspected data theft, or loss of a critical service. The time of declaration is written in the incident log.
Activation and escalation	Low and Medium: Security Analyst and IT lead. High: IR Lead activates the core CSIRT and tells management within 60 minutes. Critical: full CSIRT within 15 minutes, Executive Sponsor told within 15 minutes, legal adviser and outside help within 60 minutes. If an approver does not answer within 15 minutes, their named deputy decides.
Authority to isolate	The IR Lead (or deputy) may isolate any device, account or network segment at once, without prior approval, if there is active spread or data loss. The Executive Sponsor is told within 15 minutes (A1). Where time allows, business owners are consulted before a planned shutdown.
Documentation	A named scribe keeps a time-stamped incident log (WAT) of facts, decisions, owners, reasons, evidence handled and messages sent. The log is stored outside the affected systems. Assumptions are labelled. Any decision that loses evidence or causes an outage is recorded with its reason.
Plan review	Reviewed every 12 months, after every Critical or High incident, after every exercise, and when key systems or staff change. The IR Lead owns the plan; the Executive Sponsor approves changes.
Link to business continuity	The business impact analysis sets recovery priorities, recovery time targets and acceptable data loss. The Business Owner (Head of Exams and Academic Operations) sits on the CSIRT. Continuity work (rescheduling an exam, alternative teaching, manual processes) runs alongside technical recovery. The Business Owner approves service return after security checks.
Framework link	Preparation follows Govern, Identify and Protect. Response follows Detect, Respond and Recover (NIST, 2025). Lessons learned feed back into all functions. CISA ransomware guidance shapes the containment and recovery checks (CISA, 2023).

2.2 CSIRT structure

Northbridge has only three IT staff and one security analyst. So, some people hold more than one role; every role has a deputy named, and outside help is arranged in advance.

Table 9. CSIRT roles

Role	Filled by	Main responsibilities
Incident Manager / IR Lead (IM)	Senior IT or risk manager (me in this case)	Declares the incident, sets priorities, authorises containment, runs the log and briefings, leads the post-incident review.
Security Analyst (SA)	In-house security analyst	Triage, log analysis, threat hunting, account and cloud checks, confirm systems are clean.
Digital Forensics Lead (DF)	Trained IT staff member, supported by the external forensic partner (fictional: Example DFIR Partner Ltd)	Plans evidence collection, imaging, chain of custody and forensic analysis.
IT Operations Lead (IT)	Senior IT staff member	Isolation, rebuilds, restoration, backup handling, system changes.
Business Owner (BO)	Head of Exams and Academic Operations	Business impact, examination decisions, approval of restored services.
Legal and Privacy Adviser (LP)	Data protection officer, with external lawyer	Notification duties, privacy risk, contact with regulator and police, checks wording of messages.
Communications Lead (COM)	Marketing or administration manager	Staff, learner and media messages; manage channels.
Executive Sponsor (EX)	Principal	Approves spending, risk acceptance and major business decisions; signs off closure.
Scribe	Administrative officer	Time-stamped log, action tracker, helps with the evidence log.

Getting extra support. Northbridge should keep: a retainer with an external digital forensics and incident response (DFIR) provider; cyber insurance with a 24-hour hotline; a Microsoft support route; and the contact for Ghana's national CERT (CERT-GH). A partner institution can lend IT staff or an exam venue. The IR Lead calls for outside help when severity is Critical, when more than two workstreams run at once, or when internal staff have worked eight hours without a break. Calls are made within the first 60 minutes (A6). Outside responders get time-limited accounts, a written scope, a confidentiality agreement and a named internal supervisor.

2.3 RACI matrix

R = Responsible (does the work). **A** = Accountable (the one person who owns the result and signs it off). **A/R** = both. **C** = Consulted before the decision. **I** = Informed after. Each activity has exactly one A. Role codes are in Table 9. The scribe records every activity and is not shown.

Table 10. RACI matrix

Activity	IM	SA	DF	IT	BO	LP	COM	EX
1. Detection and triage	A	R	C	C	I	–	–	I
2. Analysis and scoping	A	R	R	C	C	C	I	I
3. Containment	A	R	C	R	C	I	I	I
4. Evidence handling	I	R	A/R	R	–	C	–	–

Activity	IM	SA	DF	IT	BO	LP	COM	EX
5. Stakeholder communication	C	–	–	I	C	C	R	A
6. Assessing reporting obligations	C	C	C	I	I	R	C	A
7. Eradication	A	R	C	R	I	–	I	–
8. Restoration approval	C	R	C	R	A	C	I	I
9. Recovery and validation	C	R	C	A/R	C	–	I	I
10. Closure and post-incident review	R	R	R	R	C	C	C	A

2.4 Readiness improvements and checklist

Table 11. Preparation improvements

Improvement	Owner	Resources needed	How readiness is checked
Backup readiness: immutable or offline copies of FS01, LMS01 and BAK01 settings; separate backup credentials; regular restore tests.	IT Operations Lead	Immutable (write-once) storage or offline media; a test environment; about two staff days per quarter.	Restore tests of FS01 and LMS01 every quarter, with checksum comparison and timed against targets. First test within 30 days.
Accessible incident contact list and call tree, kept offline and outside corporate systems.	Incident Manager	Printed wallet cards; encrypted phone list held by each CSIRT member; a secure messaging group.	Quarterly call test reaches every CSIRT member within 15 minutes; list checked monthly.
Tools: EDR on every server, central logging, alerts for out-of-hours admin logons.	Security Analyst	Server EDR licenses; log forwarding; alert rules.	Coverage report shows 100% of servers; a test logon like E03 raises an alert within 5 minutes.
Account hardening: replace svc_backup with a least-privilege account kept in a password vault; phishing-resistant MFA and conditional access in M365.	IT Operations Lead with Security Analyst	Password vault; conditional access policies; MFA keys or number-matching app.	Quarterly privilege review; MFA report shows 100% of staff and admins; a test sign-in from a new country is blocked.
Secure communication: agreed backup channel and ready-made message templates for staff, learners and media.	Communications Lead	Bulk SMS service; a status web page hosted away from the portal; approved templates.	In an exercise, templates are sent within 10 minutes of the trigger.
Training and support: payroll-themed phishing training for all staff; role training for the CSIRT; signed DFIR retainer.	Security Analyst (training); Legal and Privacy Adviser (retainer)	Training platform; 2 hours per person per year; signed contract.	Attendance at least 95%; phishing clicks rate falls each quarter; retainer signed and hotline tested.

Task 3: Response playbook and evidence preservation

3.1 Playbook for the first 24 hours

Times are WAT on Day 0 unless stated. Actions 1 to 7 fall in the first 60 minutes (08:45 to 09:45). "Pre-approved" means the plan already gives this authority (Table 8), so there is no delay.

Table 12. Response playbook

Time / stage	Action	Owner	Approval	Evidence to keep	Completion check
1. 08:45–08:50 Declare	Declare a Critical (provisional) incident. Open the incident log. Call CSIRT members by phone (E08). Tell the Principal.	IM; Scribe	Pre-approved (A1)	Declaration time, attendee list, call log.	Log open; all core roles confirmed.
2. 08:50–09:00 Short-term containment	Isolate FIN-PC07 and FS01 from the network using EDR containment or by disabling the switch port. Do not switch them off.	IT; SA	IM (pre-approved)	EDR containment record; photos of ransom notes and screen; time of isolation.	No network traffic from the hosts; hosts still powered on.
3. 08:50–09:05 Protect backups	Disconnect BAK01 from the production network. Pause backup jobs. Secure the Friday offline backup. Disable svc_backup. Do not delete any jobs or snapshots.	IT	IM (pre-approved)	BAK01 logon and job logs exported before the change; svc_backup logon history.	BAK01 unreachable from production; svc_backup disabled; no live sessions.
4. 08:55–09:10 Account containment	For the finance officer: end all sessions and tokens, reset the password from a clean device, check MFA methods, block the unfamiliar IP, check inbox rules and app grants.	SA	IM	Entra ID sign-in and audit log export taken before changes.	No successful sign-in after revocation; MFA confirmed with the user by phone.
5. 09:00–09:15 Secure communication	Move coordination to phone and a secure messaging group. Treat corporate email as untrusted for incident details.	COM	IM	Channel and member list.	All CSIRT members reached on the new channel.

Time / stage	Action	Owner	Approval	Evidence to keep	Completion check
6. 09:00–09:30 Evidence captures	Capture memory from FIN-PC07 if it can be done safely within 20 minutes. Export proxy, firewall, M365 and Windows logs. Plan disk imaging.	DF; SA	IM	Evidence registers entries (Table 13).	Each item logged with time, collector, hash and storage once collected.
7. 09:00–09:45 Exam decision	Business Owner and IM weigh the options: reschedule, a clean isolated environment, or a paper alternative. Go / no-go at 09:45.	BO	EX	Decision record with reasons.	Decision recorded and announced by 09:50.
8. 09:15–10:15 Scope check	Hunt for the same indicators on all hosts (EDR, and manual checks on servers without EDR). Look for sign-ins from the unfamiliar IP, new admin accounts, scheduled tasks, inbox rules and OAuth apps. Find and block the E04 cloud destination.	SA	IM	Queries, results, host coverage table.	Every server, endpoint and key account marked clean, affected or unknown.
9. 09:20 and 09:50 Notify	Send the executive briefing (09:20). Send the learner notice after the exam decision (09:50). Engage insurer, forensic partner and legal adviser.	COM; LP	EX; BO	Messages as sent, times, call notes.	Management confirms receipt by phone.
10. 10:00–14:00 Investigation	Answer Q1 to Q5 (Table 7): entry point, svc_backup misuse, data sent out, LMS01 state, other accounts.	SA; DF	IM	Analysis notes, indicator list, timeline updates.	Each question marked answered, partly answered or open.
11. 14:00–20:00 Long-term containment	Segment the network; block malicious domains; enforce conditional access; force password resets for finance and admin accounts; install EDR on servers.	IT; SA	IM	Change records; firewall rule export.	No new alerts for 4 hours; rules checked.

Time / stage	Action	Owner	Approval	Evidence to keep	Completion check
12. 14:00–22:00 Eradication	Rebuild FIN-PC07 and FS01 from clean media. Remove persistence on other hosts. Close the entry route (block the attachment type, tighten mail filtering, enforce MFA). Rotate all privileged passwords and secrets (reset krbtgt twice if a domain exists, A4).	IT; SA	IM	Rebuild records; indicator scan results.	Clean EDR scan; no indicators remain.
13. Day 0–Day 1 Recovery preparation	Choose a backup (section 3.5), restore it into an isolated network, scan it and test it.	IT; SA	BO for go-live	Restore logs, checksums, scan reports.	All acceptance criteria in Table 15 met.
14. Day 1 Phased return and monitoring	Return LMS01 and exam content first, then FS01 data in priority order. Extra monitoring for at least 72 hours.	IT; SA	BO	Monitoring log; change record.	No signs of the attacker returning.
15. By 24 hours Close first phase	Write a handover note, update the timeline, list open questions, set the review date, update stakeholders.	IM	EX	Incident log and action tracker.	Handover accepted; review booked.

3.2 Checking for wider compromise

I will search for the same indicators on every endpoint, server and account, using EDR where it exists and manual checks on servers without it. I will look for new admin accounts, scheduled tasks and services, remote access tools, mailbox forwarding rules, OAuth app consents, and sign-ins from the E02 IP. I will check proxy and DNS logs from all hosts for the E04 cloud destination, and review svc_backup activity on every server it can reach. I will also compare events with E01 to E08 to look for earlier attacker activity. **Any host without monitoring is treated as "unknown", not "clean", until it is checked.**

3.3 Two difficult decisions

Decision 1: containment versus evidence. I isolate the machines from the network but do **not** switch them off. Isolation stops the spread, while keeping the machines preserves memory and disk evidence. Immediate isolation is necessary when encryption is still active (E06), when data may still be leaving (E04), or when the attacker may still have admin access to BAK01 (E03). If memory capture on FIN-PC07 can be done safely within about 20 minutes, it is done after isolation, but it never delays protecting BAK01 and FS01. If switching a machine off becomes the only safe option, I record why. Any evidence loss is written in the log: what was lost, why, when, who decided, and which other sources (EDR, proxy, M365 and Windows logs) partly replace it. The business impact (FS01 and portal outage, effect on the exam) is recorded with the same decision.

Decision 2: restoring exam access while backups are uncertain. I will **not** restore the portal into production from the unverified network backup just to meet 11:00. A bad backup could bring the attacker back, damage assessment records and make exam results unreliable. The preferred route is

a clean, isolated rebuild of LMS01, using exam content from trusted master copies (A5) or the Friday offline backup, tested before use. The exam goes ahead only if this environment passes the acceptance criteria and the Business Owner approves at the 09:45 go / no-go. Otherwise, it is rescheduled and learners are told. The cost is a delay for 100 learners, and up to about 64 hours of lost data if we use the offline backup. I judge this smaller than the risk of reinfection and untrustworthy results.

3.4 Evidence register and chain of custody

All items below are **planned and not yet collected**. No hash, acquisition or custody transfer has happened, so none is claimed. The date and time column shows the planned collection window in WAT.

Table 13. Evidence registers

ID	Source	Planned collection method	Collector	Planned date/time (WAT)	Integrity check	Secure storage	Custody transfers
EV-01	Memory and live data, FIN-PC07 (E06)	EDR live response or approved memory tool, saved to an encrypted external drive.	DF Lead	Day 0, 09:00–09:20 (planned)	SHA-256 to be calculated at capture (not yet generated).	Encrypted drive in a locked cabinet.	Custody form; none yet.
EV-02	Disk image, FIN-PC07, after isolation	Forensic image with a write blocker or EDR forensic feature.	DF Lead	Day 0, 10:00–12:00 (planned)	Hash of source and image to be compared (not yet generated).	As EV-01; analysts use read-only copies.	Custody form; none yet.
EV-03	FS01 logs, ransom note, sample of encrypted and original files (E06)	Targeted collection; snapshot if virtual; full image by forensic partner.	DF Lead; IT assists	Day 0, 09:30–13:00 (planned)	Hash of each item (not yet generated).	As EV-01.	Custody form; none yet.
EV-04	M365 sign-in, audit and mailbox logs (E02)	Export from Entra ID and Purview by an admin before any change.	Security Analyst	Day 0, 08:55–09:15 (planned)	Hash of each export (not yet generated).	Restricted evidence stores outside the file server.	Custody form; none yet.
EV-05	Windows security logs, FS01 and BAK01 (E03)	Event log export with wevtutil or EDR.	Security Analyst	Day 0, 09:00–09:30 (planned)	Hash of each log (not yet generated).	As EV-04.	Custody form; none yet.

ID	Source	Planned collection method	Collector	Planned date/time (WAT)	Integrity check	Secure storage	Custody transfers
EV-06	Proxy and firewall logs, Day −1 to Day 0 (E04)	Export from proxy and firewall consoles for the time window.	Security Analyst	Day 0, 09:15–09:45 (planned)	Hash of exports (not yet generated).	As EV-04.	Custody form; none yet.
EV-07	Backup job logs and BAK01 settings (E05)	Export before disconnecting if safe; otherwise from the console after isolation.	IT Ops Lead (DF oversees)	Day 0, 09:00–09:30 (planned)	Hash of exports (not yet generated).	As EV-04.	Custody form; none yet.
EV-08	Original payroll email with headers and attachment (E01)	Export message with full headers; store attachment safely for sandbox testing.	Security Analyst	Day 0, 09:15–09:45 (planned)	Hash of message and attachment (not yet generated).	Password-protected archive in an isolated lab.	Custody form; none yet.

Custody and access rules. Every transfer is written on the custody form with: evidence ID, description, who handed it over, who received it, date and time (WAT), purpose, seal condition and hash check. Only DF Lead, the IR Lead and the Legal and Privacy Adviser may open the evidence store. Originals are never worked on; analysts use verified copies. Every access and copy is logged. Personal data in evidence is kept to the minimum needed, and the legal adviser sets retention and any legal hold. This follows NIST forensic guidance (Kent et al., 2006).

3.5 Eradication, credentials, recovery and acceptance

Removing persistence and closing the way in. I will rebuild FIN-PC07 and FS01 from clean media instead of trying to clean them, because hidden backdoors are easy to miss. On other hosts I will check scheduled tasks, services, registry run keys, new accounts, remote access tools, mailbox rules and OAuth apps. The likely entry point (E01) is addressed by blocking the attachment type and sender, tightening mail filtering, restricting macros and scripts, and confirming through Q1 whether there was another way in.

Securing credentials. Reset the finance officer's password and end all sessions. Replace svc_backup with a new least-privilege account kept in a vault, so that one account can no longer control both production and backups. Reset all admin and finance staff passwords from a clean device. Re-register MFA, review conditional access, and rotate service secrets and API keys. If a domain exists, reset the krbtgt account twice (A4).

Table 14. Restoration order, recovery time and acceptable data loss

Order	System or service	Recovery time target (RTO)	Acceptable data loss (RPO)	Reason
1	Identity, EDR, logging and a clean admin workstation	Within 8 hours	None (settings only)	Needed to restore safely and to watch for the attacker.
2	LMS01 portal and exam content	Within 24 hours (exam rescheduled into this window)	Up to about 64 hours (Friday offline copy) unless a new clean copy is proven	Most urgent business service; exam content can come from trusted master copies.
3	FS01 academic and admissions files	Within 72 hours	Up to about 64 hours; staff re-create recent work	Needed for teaching and learner records.
4	FS01 finance files and a replacement FIN-PC07	72 hours to 5 days	Up to about 64 hours; checked against bank and payroll records	Sensitive; restored only after finance accounts are secured.
5	Rebuilt BAK01 with immutable copies; remaining endpoints	Within 7 days	Not applicable	Restores long-term resilience.

Choosing and testing a backup. The options are the Friday 17:00 offline backup and any network backups taken before the first sign of attack (E01, Sunday). Because we do not know how long the attacker was inside, I prefer an offline copy from before the earliest confirmed indicator and accept the data loss that comes with it. I will not trust the "success" message in E05 on its own. To test the backup, I will:

1. Check the catalogue and checksums.
2. Restore it into an isolated network with no route to production.
3. Scan it with up-to-date antivirus and EDR, and search for .locked files, the ransom note and unknown programs.
4. Compare file counts and sizes with the last known baseline, and open a random sample of files.
5. Test LMS01: sign in, open materials and submit a test assessment.

I restore data onto clean rebuilt systems, not whole system images from the attack period. After going live, I monitor with stronger EDR alerts and daily log reviews for at least 72 hours (CISA, 2023).

Table 15. Recovery acceptance criteria (all must be met before the Business Owner approves service return)

No.	Criterion	Evidence	Sign-off
1	Entry route found, or protective controls in place (mail filtering, MFA, blocked indicators).	Written analysis and changing records.	Security Analyst
2	All compromised and admin passwords reset; svc_backup replaced; MFA confirmed.	Reset log and audit export.	IT Ops; Security Analyst

No.	Criterion	Evidence	Sign-off
3	Backup catalogue and checksums verified; no malware found; sample file test passed (for example, 50 random files, 100% open correctly).	Restore log, scan reports, test sheet.	Security Analyst
4	LMS01 works sign-in, open materials, and submits a test assessment.	Test record.	Business Owner
5	EDR installed and reporting on every restored server; logging active.	Coverage report.	Security Analyst
6	No signs of compromise in scope checks for at least 24 hours before return.	Hunt results and monitoring log.	Security Analyst
7	A new verified backup of the restored service exists; a rollback plan is written.	Backup report.	IT Ops
8	Written with approval from the Business Owner; messages ready.	Approval record.	Business Owner (A)

Task 4: Communication and escalation

4.1 Communication matrix

Table 16. Communication matrix

Stakeholder group	Trigger	Message owner	Channel	Approver	Update frequency
Learners	Declaration and exam decision (by 09:50); any change in service or data risk.	Communications Lead	SMS, web status banner, phone helpline. Email only once it is proven safe.	Executive Sponsor; Legal adviser for any statement about data	14:00, then at least every 4 hours until restored, then daily.
Management and Principal	Declaration; each major decision; change in severity.	Incident Manager	Phone and secure messaging group; short face-to-face briefing.	Incident Manager	Hourly for the first 4 hours, then every 2 to 4 hours.
Teaching and admin staff	Declaration; instructions on devices and email.	Communications Lead	Phone tree, secure group, printed notices on site.	Incident Manager	Twice daily.
IT and security staff	Declaration; every task given.	Incident Manager	Phone and secure messaging group.	Incident Manager	Continuous; shift handover every 8 hours.
Service providers (Microsoft, backup vendor, forensic partner, insurer)	Critical declaration; need for specialist help; insurance notice.	IT Operations Lead (Legal adviser for insurer)	Phone first, using known support numbers, then secure email from a clean account.	Executive Sponsor	On engagement, then each shift.
Legal and privacy advisers	Possible data theft (E04) or an extortion claim.	Incident Manager	Phone; secure document share outside FS01.	Incident Manager	Immediately, then with each new finding about data.
Media and public	Journalist question or public post.	Communications Lead	Approved holding statement; one spokesperson.	Executive Sponsor and Legal adviser	Only when needed, or at agreed times.

Backup channel if email is unsafe (E08). Use the phone call tree, a secure messaging group created for the incident, bulk SMS to learners' registered numbers, a banner on the public website

hosted away from the portal, and printed notices on site. Never rely on contact details stored only on FS01. No sensitive details are sent by SMS or consumer chat apps.

4.2 Executive briefing (09:20 WAT, Day 0)

> Northbridge is responding to a suspected ransomware attack, declared Critical at 08:45. Confirmed: the finance workstation FIN-PC07 and the shared server FS01 hold encrypted files and a ransom note (E06). Learners cannot open materials or submit assessments (E07). Overnight logs also show an unfamiliar sign-in to a finance account, unusual use of the backup service account, and a 1.2 GB upload to unknown cloud storage (E02 to E04). Not yet known whether learner or finance data was stolen, how the attacker got in, and whether our backups are safe. Actions taken affected systems isolated, backups and admin accounts protected, evidence preservation started, and coordination moved to phones because email is not yet trusted. Decisions needed by 09:45: (1) approve postponing the 11:00 exam for 100 learners unless a tested clean system is ready; (2) approve hiring our forensic partner and notifying the insurer; (3) approve the learner notice. Legal advice on notification has been requested; no breach has been declared. Next update: 10:15 WAT by phone.

(166 words)

4.3 Learner notice (09:50 WAT, Day 0)

> Important notice for learners. Northbridge Skills Institute is dealing with a technical incident that affects the learning portal.
>
> You may not be able to open course materials or submit work.
>
> Today's 11:00 online examination will not start at that time.
>
> We will confirm the new date and time by 14:00 today on the institute website and by text message.
>
> Please do not try to log in again and again.
>
> Do not open unexpected emails or attachments that seem to come from the institute and never share your password or verification codes.
>
> Keep copies of any work you have finished.
>
> We are checking whether any personal information was affected and will tell you quickly if you need to act.
>
> For urgent questions, call the learner helpline on +000 000 0000. Next update: 14:00 WAT.

(133 words; helpline number is fictional; assumes the Business Owner approves postponement at 09:45)

4.4 Notification duties

The Legal and Privacy Adviser decides whether a legal duty to notify exists. I assume Northbridge is in Ghana (A2). The adviser will:

1. Confirm the jurisdiction of Northbridge and of the affected learners (some may be covered by other countries' laws).
2. Check the Data Protection Act, 2012 (Act 843), current guidance from Ghana's Data Protection Commission, contracts with accreditation or funding bodies, and insurance policy conditions.
3. Work with the Security Analyst and Forensics Lead to find out whether personal data was accessed or taken, who is affected and how serious the risk is.
4. Record the time Northbridge first had reasonable grounds to believe data was accessed.
5. Confirm the recipients, content and timing in writing before anything is sent.

Under Act 843 (section 31, “security compromises”), when there are reasonable grounds to believe personal data has been accessed or obtained by an unauthorised person, the data controller must notify both the Data Protection Commission and the affected data subjects as soon as reasonably practicable after discovery (Republic of Ghana, 2012; Data Protection Commission, n.d.). The Act does not set a fixed number of hours, so I do not invent one. The adviser must check the current text and Commission guidance before relying on this.

Operational notice versus formal breach notification. An operational notice (the learner notice, staff instructions, a media holding statement) tells people what is happening and what to do. It makes no claim about whether data was breached. A formal breach notification goes to the regulator or affected people only after legal review. It uses the required content and states only what is known. The ransomware alone does not start a notification deadline. The attacker's claim and screenshot are kept as evidence but are not treated as proof of theft.

Table 17. Escalation rules

Trigger	Escalate to	Timeframe
Confirmed or likely theft of personal or finance data	Legal and Privacy Adviser; Executive Sponsor	Within 30 minutes
Extortion demand or threat to publish	IM, Executive Sponsor, Legal adviser; insurer; police advice through counsel	Within 30 minutes
Backups found unusable or compromised	Executive Sponsor and Business Owner	Within 15 minutes
Media question or public post	Communications Lead; Executive Sponsor	Within 15 minutes; no one else comments
New hosts or accounts found affected	Incident Manager; severity review	Immediately
Approver does not respond	Named deputy	After 15 minutes

Task 5: Tabletop exercise and improvement plan
A simulated tabletop exercise, taking each role in turn. No real incident, attacker, decision or system action took place

5.1 Exercise design

Format: 60-minute discussion-based exercise. No live systems are changed.

Objectives: (1) test the first-hour response and who has the right to decide; (2) test how the plan copes with exam pressure when backups are unverified; (3) test communication with learners, management and the media; (4) test escalation when new information arrives.

Participants: Facilitator (Incident Manager), Security Analyst, Forensics Lead, IT Operations Lead, Business Owner, Legal and Privacy Adviser, Communications Lead, Scribe and Executive Sponsor.

Table 18. Agenda

Minute	Activity
0–5	Introduction, ground rules, reading of the evidence pack (E01 to E08).
5–10	First actions: declaration, isolation, evidence, communication channel.
10	Inject 1: management asks to reopen the portal before 11:00, even with an unverified backup.
20	Inject 2: the attacker claims to hold all 1,800 learner records and threatens to publish them in 12 hours (screenshot of unknown authenticity).
28	My own inject: the helpdesk reports that two more staff received the same payroll email, and one clicked a link.
35	Inject 3: a test restore of the latest network backup fails with an “unreadable snapshot” error.
45	Inject 4: a social media post says the exam is cancelled; a journalist asks if learner data was exposed.
52–60	Hot debrief, scoring against success criteria, actions captured.

Measurable success criteria:

- **SC1:** every inject gets a recorded decision within 5 minutes.
- **SC2:** no restore is approved without checking the written acceptance criteria (target 100%).
- **SC3:** every required message is drafted and approved within 10 minutes of its trigger.
- **SC4:** all CSIRT members are reached within 15 minutes using a channel that does not depend on FS01 or email.
- **SC5:** no sensitive incident detail is sent over corporate email.

5.2 Simulated walkthrough by role

Table 19. Simulated responses (simulation results, not real events)

Inject	Role	Simulated response
Minute 10	Incident Manager	Refuses to reopen from the unverified backup. Offers three options: reschedule, a clean isolated environment with a go / no-go check, or a paper alternative. Escalates to the Executive Sponsor.

Inject	Role	Simulated response
	Business Owner	Puts the integrity of results first; agrees to a go / no-go at 09:45 and prepares learner messages.
	IT Operations Lead	Reports that a clean LMS01 with trusted exam content cannot be built and tested before 11:00 with current staff.
	Security Analyst	States the backup is unverified and could bring the attacker back; asks that nothing is restored into production.
Minute 20	Legal and Privacy Adviser	Treats the claim as unverified but starts a breach assessment; advises not to reply to the attacker; asks for the message and screenshot to be preserved.
	Forensics Lead	Plans to compare file names, fields and folders in the screenshot with FS01 and finance data; collects the original message.
	Communications Lead	Prepares a holding statement that neither confirms nor denies data theft.
	Executive Sponsor	Agrees there will be no contact with the attacker and no payment decision without legal and insurer advice.
Minute 28	Security Analyst	Searches all mailboxes for the attachment; isolates the Admissions PC; ends that user's sessions.
	IT Operations Lead	Removes the email from all mailboxes after copies are kept as evidence; checks EDR on that PC.
	Incident Manager	Widens the scope: the attack is not limited to finance; extends password resets to Admissions.
Minute 35	IT Operations Lead	Reports the snapshot cannot be read; stops using the network backup.
	Forensics Lead	Keeps the failed snapshot as evidence in case it was tampered with.
	Incident Manager	Switches to the Friday offline backup; tells management that about 64 hours of data may be lost and the exam cannot be run today.
	Business Owner	Reschedule the exam to Day 1 or later and arrange an alternative.
Minute 45	Communications Lead	Posts a correction on official channels: the exam is postponed, not cancelled, and the new time will follow. Send the journalist to the single spokesperson.
	Legal and Privacy Adviser	Approves wording that says the investigation is ongoing, with no claim that data was or was not exposed.
	Executive Sponsor	Approves the statement.

5.3 Decision log

Table 20. Simulated decision log

Inject	Decision	Owner	Rationale	Communication	Effect on response or recovery plan
1 (min 10)	Do not restore the unverified network backup into production. Reschedule unless a clean, tested environment is ready by the go / no-go time.	Business Owner, advised by IM	Reinfection and unreliable results are worse than a delay (E05).	Learner notice; management update.	Exam moves to recovery stage 2 (Table 14); clean-build path prepared in parallel.
2 (min 20)	Treat the extortion claim as credible for planning. Start a breach assessment. Preserve the screenshot.	IM with Legal adviser	The claim is unverified, but E04 makes theft possible; our response must not depend on whether the screenshot is real.	Executive update; insurer and police advice sought through counsel.	Data-impact analysis (Q3) becomes the top investigation priority.
2 (min 20)	No contact with the attacker and no payment decision without legal and insurer advice.	Executive Sponsor	Paying does not guarantee data deletion or recovery; advice is needed first.	Restricted briefing to counsel and insurer.	Recovery plan stays based on our own backups.
Own (min 28)	Isolate the Admissions PC, end the user's sessions, remove the email after preserving it.	Security Analyst	A second user shows the phishing campaign reached more people.	Phone alert all staff.	Scope grows; extra eradication and password reset tasks added.
3 (min 35)	Stop using the network backup. Use the Friday offline backup and raise the data-loss estimate to about 64 hours.	IM with IT Ops Lead	The unreadable snapshot is unreliable and may have been tampered with.	Executive Sponsor and Business Owner talked within 15 minutes.	Table 14 targets are now based on the offline backup; restore order unchanged.

Inject	Decision	Owner	Rationale	Communication	Effect on response or recovery plan
4 (min 45)	Issue a holding statement confirming the exam is postponed. Send the journalist to one spokesperson.	Communications Lead	Stops rumors and avoids unverified claims about data.	Updated learner notice; media statement approved by Executive Sponsor and Legal adviser.	Social media monitoring added to the communication workstream.

5.4 Evaluation against success criteria

Table 21. Simulated results

No.	Criterion	Simulated result	Outcome
SC1	Decision within 5 minutes of each inject	Four of five injections got a decision in time. The backup failure took about 8 minutes because the fallback options were not written in advance.	Partly met
SC2	Acceptance criteria checked before any restore	Both restore-related decisions (injects 1 and 3) referred to Table 15.	Met
SC3	Messages approved within 10 minutes	Executive and learner messages met the target. The media statement took about 12 minutes because the two approvers were not available together.	Partly met
SC4	All CSIRT members reached within 15 minutes without FS01 or email	Only people whose numbers the facilitator knew were reached quickly; the lost contact list (E08) delayed the rest.	Not met
SC5	No sensitive detail over corporate email	All sensitive messages used phone or security group.	Met

5.5 Improvement plan

Table 22. Improvements

#	Improvement	Priority	Owner	Target	Measurable evidence of completion
1	Create an offline call tree and printed contact cards for all CSIRT members and deputies.	High	Incident Manager	7 days	Test call reaches every member within 15 minutes.
2	Write pre-approved exam continuity options and go / no-go criteria.	High	Business Owner	14 days	Signed criteria; a re-run of inject 1 gives a decision in 5 minutes or less.

#	Improvement	Priority	Owner	Target	Measurable evidence of completion
3	Move to immutable or offline backups and run a restore test of FS01 and LMS01.	High	IT Operations Lead	Restore test in 30 days; immutable storage in 90 days	Test report with checksums and measured restore time.
4	Install EDR on all servers and alert on out-of-hours admin logons.	High	Security Analyst	30 days	Coverage report shows 100% of servers; test alert received.
5	Prepare holding statements, a media protocol, and joint approval by the Executive Sponsor and Legal adviser (with deputies).	Medium	Communications Lead	14 days	Templates approved; approval in 10 minutes or less in a re-test.
6	Write an extortion-handling procedure with insurer, lawyer and police contacts.	Medium	Legal and Privacy Adviser	30 days	Procedure approved; contact numbers tested.

Review and closure. A hot debrief happens within 48 hours of exercise. The post-incident review is due **within 10 working days** after the incident (or exercise) is closed, with the full CSIRT and the Executive Sponsor.

The Incident Manager tracks each action and marks it done only when the evidence in Table 22 is shown.

The Executive Sponsor approves the closure report and formally closes the actions. Open items are reviewed monthly, and overdue High-priority items go to management.

Task 6: Case study analysis and critical reflection

Case summary. Slide 16 describes a mid-size healthcare organisation (2,500 staff) hit by a Ryuk ransomware variant after an employee opened a phishing attachment. The malware hid and moved across the network 72 hours before encryption started (ICDFA, n.d.).

Response strengths. First, preparation paid off: a pre-established IR team and playbooks were activated as soon as EDR raised alerts on Day 4. Second, containment was fast: network segments were isolated and infected systems quarantined, and segmentation clearly limited the spread. Third, offline backups were checked and found intact before use, so systems were rebuilt from clean copies and no ransom was paid.

Limitations. First, detection was late. The attacker kept access and moved sideways for 72 hours without being noticed; EDR was only alerted once encryption began. Second, "no patient data exfiltration confirmed" does not prove nothing left. After 72 hours of hidden access, the slide does not show which logs support this finding.

Changes I would transfer to Northbridge. (1) Tested offline backups, which the case calls the critical factor. Northbridge's network backups are not immutable or tested, and svc_backup reached BAK01 (E03), so Table 22 item 3 is essential. (2) Network segmentation. At Northbridge, one finance PC and one service account reached both the file server and the backups (E03, E06). Separating finance, academic servers and backups would cut that path.

72 hours versus seven days. The case restored critical systems in 72 hours but needed seven days for full restoration. The first brings back the services people need most, often in reduced form. The second covers every remaining system after forensic checks and rebuilding. Rushing it risks reinfection, so Northbridge restores the portal first (Table 14).

Evidence needed before saying "no patient data was stolen". Complete, trusted proxy, firewall, DNS, EDR and file-access logs for the whole 72-hour period; proof that every system the attacker reached was monitored; analysis of every outbound transfer; and checks of known leak sites. Without this, the honest wording is "no evidence of theft was found".

A decision I would revise. The tabletop showed slow backup decisions (SC1) and failed team contact (SC4). I would pre-write the exam and backup fallbacks and make an offline phone call tree the first action after declaration (Table 22, items 1 and 2).

References

Citation style: Harvard (author-date). The table links each source to the decisions it supports.

Source	Decision or section supported
CISA and partners (2023) #StopRansomware Guide. Cybersecurity and Infrastructure Security Agency. Available at: https://www.cisa.gov/resources-tools/resources/stopransomware-guide (Accessed: 14 October 2026).	Containment, scope checks, backup testing, recovery and monitoring (Tables 8, 12 and 15; section 3.5).
Data Protection Commission, Ghana (n.d.) Data Protection Commission. Available at: https://dataprotection.org.gh (Accessed: 14 October 2026).	Regulator guidance and breach reporting route (section 4.4).
ICDFA (n.d.) Incident Response Planning. GRC105 Incident Management and Business Continuity, Week 20. Teaching deck, slides 1 to 18.	Four-stage structure of the report; healthcare ransomware case study on slide 16, used for the critique and the backup and segmentation changes (Task 6).
Kent, K., Chevalier, S., Grance, T. and Dang, H. (2006) Guide to Integrating Forensic Techniques into Incident Response (NIST SP 800-86). Gaithersburg, MD: National Institute of Standards and Technology.	Evidence collection, integrity checks and chain of custody (Table 13).
NIST (2025) Incident Response Recommendations and Considerations for Cybersecurity Risk Management (SP 800-61 Revision 3). Available at: https://csrc.nist.gov/pubs/sp/800/61/r3/final (Accessed: 14 October 2026).	Plan structure, CSF 2.0 alignment, roles and continuous improvement (Tables 8 to 11; Task 5).
NIST (n.d.) Incident Response project. Available at: https://csrc.nist.gov/projects/incident-response (Accessed: 14 October 2026).	Framework and life-cycle overview (Tables 8 and 12).
Republic of Ghana (2012) Data Protection Act, 2012 (Act 843). Accra: Republic of Ghana.	Breach notification duty and jurisdiction assumption (A2; section 4.4).

AI Assistance Statement

The analysis, decisions and answers to the six tasks in this assignment are my own. I worked through the Northbridge scenario myself and wrote my own drafts. In line with the ICDFA course policy, I used AI tools only for support, as follows:

- **ChatGPT Pro (OpenAI) and Gemini (Google):** to check my understanding of some concepts and to review my drafts against the assignment brief.
- **Claude Pro (Anthropic):** to combine my two drafts into one document, simplify the English, format the tables, and help structure the Task 6 case study from slide 16.

I reviewed and edited all AI suggestions, and checked them against the assignment brief, the teaching slides and the cited sources. I take full responsibility for the accuracy of this work and can explain any part of it if asked.